

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

Vulnerability Assessment Report

Target: scanme.nmap.org

Date: October 01, 2026

1. Executive Summary

AI unavailable: GEMINI_API_KEY not configured. Set env var or edit config.py

Overall Risk: **Unknown (0/10)**

2. Top Findings

No findings reported.

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

3. Penetration-Test Details & Exploitation Options

3.1 Test Details & Methodology

Target: scanme.nmap.org Scan ID: 20261001_063023 Date: 2026-10-01 06:30

Ports scanned: Top 1000 most-used ports of all 65535 (selection: top1000)

Network: nmap with version detection (-sV), default scripts (-sC) and the vulners NSE script; HTTP services were located via -sV and directory brute-forcing (gobuster dir) was executed against the detected HTTP port(s) rather than assuming port 80.

Web audit base URL (nmap-confirmed): http://scanme.nmap.org

No HTTP-speaking ports were detected by nmap -sV.

Nuclei (default template scanner): unavailable this run — nuclei binary not found. Install it: sudo apt install nuclei (or download from <https://github.com/projectdiscovery/nuclei>). Install the 'nuclei' binary to enable it.

Rules of engagement: all steps above are non-destructive checks performed within the authorized scope of this assessment.

3.2 Exploitation Options (authorized verification only)

1. [HIGH] Missing SPF record

Attack paths : Domain spoofing for phishing (no SPF/DMARC); BEC campaigns using look-alike sender

Difficulty : Easy

Verify : dig +short TXT <domain> # expect v=spf1 ...

Verify : dig +short TXT _dmarc.<domain> # expect v=DMARC1; p=...

Verify : Send a test email from an unauthorized host and observe lack of rejection.

Tools : dig, spfchecker, dmarcian validator

2. [HIGH] Missing DMARC record

Attack paths : Domain spoofing for phishing (no SPF/DMARC); BEC campaigns using look-alike sender

Difficulty : Easy

Verify : dig +short TXT <domain> # expect v=spf1 ...

Verify : dig +short TXT _dmarc.<domain> # expect v=DMARC1; p=...

Verify : Send a test email from an unauthorized host and observe lack of rejection.

Tools : dig, spfchecker, dmarcian validator

3. [MEDIUM] Missing security header: Strict-Transport-Security

Attack paths : Clickjacking (missing X-Frame-Options/CSP frame-ancestors); MIME-confusion scripting (missing X-Content-Type-Options); SSL-stripping (missing HSTS)

Difficulty : Informational

Verify : curl -skI <url> | grep -iE 'strict-transport|content-security|x-frame|x-content-type'

Verify : Open the page inside an <iframe> on a test page to confirm framing is allowed.

Tools : curl, browser dev-tools, nuclei (-t http/headers/)

4. [MEDIUM] Missing security header: Content-Security-Policy

Attack paths : Clickjacking (missing X-Frame-Options/CSP frame-ancestors); MIME-confusion scripting (missing X-Content-Type-Options); SSL-stripping (missing HSTS)

Difficulty : Informational

Verify : curl -skI <url> | grep -iE 'strict-transport|content-security|x-frame|x-content-type'

Verify : Open the page inside an <iframe> on a test page to confirm framing is allowed.

Tools : curl, browser dev-tools, nuclei (-t http/headers/)

5. [MEDIUM] Missing security header: X-Frame-Options

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

Attack paths : Clickjacking (missing X-Frame-Options/CSP frame-ancestors); MIME-confusion scripting (missing X-Content-Type-Options); SSL-stripping (missing HSTS)

Difficulty : Informational

Verify : `curl -skI <url> | grep -iE 'strict-transport|content-security|x-frame|x-content-type'`

Verify : Open the page inside an <iframe> on a test page to confirm framing is allowed.

Tools : curl, browser dev-tools, nuclei (-t http/headers/)

6. [MEDIUM] Missing security header: X-Content-Type-Options

Attack paths : Clickjacking (missing X-Frame-Options/CSP frame-ancestors); MIME-confusion scripting (missing X-Content-Type-Options); SSL-stripping (missing HSTS)

Difficulty : Informational

Verify : `curl -skI <url> | grep -iE 'strict-transport|content-security|x-frame|x-content-type'`

Verify : Open the page inside an <iframe> on a test page to confirm framing is allowed.

Tools : curl, browser dev-tools, nuclei (-t http/headers/)

7. [MEDIUM] Missing security header: Referrer-Policy

Attack paths : Clickjacking (missing X-Frame-Options/CSP frame-ancestors); MIME-confusion scripting (missing X-Content-Type-Options); SSL-stripping (missing HSTS)

Difficulty : Informational

Verify : `curl -skI <url> | grep -iE 'strict-transport|content-security|x-frame|x-content-type'`

Verify : Open the page inside an <iframe> on a test page to confirm framing is allowed.

Tools : curl, browser dev-tools, nuclei (-t http/headers/)

8. [MEDIUM] Missing security header: Permissions-Policy

Attack paths : Clickjacking (missing X-Frame-Options/CSP frame-ancestors); MIME-confusion scripting (missing X-Content-Type-Options); SSL-stripping (missing HSTS)

Difficulty : Informational

Verify : `curl -skI <url> | grep -iE 'strict-transport|content-security|x-frame|x-content-type'`

Verify : Open the page inside an <iframe> on a test page to confirm framing is allowed.

Tools : curl, browser dev-tools, nuclei (-t http/headers/)

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

4. Technical Remediation

No technical remediation steps provided.

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

5. Appendix: Scan Details

A. Target Information

Target: scanme.nmap.org
Scan ID: 20261001_063023

B. Network Scan

Error: [Errno 2] No such file or directory: 'nmap'

C. Web Application Scan

Server: Apache/2.4.7 (Ubuntu)

Missing security headers (6):

- Strict-Transport-Security
- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

Present security headers (0):

Detected technologies (1):

- Apache/2.4.7 (Ubuntu) (via header:Server)

Soft-404 baseline: none (server returns real 404 responses for missing paths).

Redirect chain (1 hops):

200 http://scanme.nmap.org/

Explicit redirect probe (allow_redirects=False): 200 — does NOT upgrade to HTTPS.

Note: Host does not serve TLS on port 443; HTTPS-redirect finding suppressed as not applicable.

D. DNS / Email Security

Domain: scanme.nmap.org

SPF Present: No

DMARC Present: No

I. Full Findings List

1. [HIGH] Missing SPF record

Target: scanme.nmap.org

Evidence: The DNS response does not contain an answer to the question: scanme.nmap.org. IN TXT

Remediation: Publish an SPF record listing authorized sending IPs/services.; Publish DMARC starting with p=none, monitor reports, then move to p=quarantine/reject.; Enforce MTA-STS and DNSSEC where supported by your registrar.

2. [HIGH] Missing DMARC record

Target: scanme.nmap.org

Evidence: The DNS query name does not exist: _dmarc.scanme.nmap.org.

Remediation: Publish an SPF record listing authorized sending IPs/services.; Publish DMARC starting with p=none, monitor reports, then move to p=quarantine/reject.; Enforce MTA-STS and DNSSEC where supported by your registrar.

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

3. [MEDIUM] Missing security header: Strict-Transport-Security

Target: <http://scanme.nmap.org>

Evidence: GET <http://scanme.nmap.org> -> no 'Strict-Transport-Security' header

Remediation: Identify the web server / reverse proxy in front of the application.; Add the missing security header globally so every response carries it.; Verify with a re-scan that the header is present on all endpoints.

4. [MEDIUM] Missing security header: Content-Security-Policy

Target: <http://scanme.nmap.org>

Evidence: GET <http://scanme.nmap.org> -> no 'Content-Security-Policy' header

Remediation: Identify the web server / reverse proxy in front of the application.; Add the missing security header globally so every response carries it.; Verify with a re-scan that the header is present on all endpoints.

5. [MEDIUM] Missing security header: X-Frame-Options

Target: <http://scanme.nmap.org>

Evidence: GET <http://scanme.nmap.org> -> no 'X-Frame-Options' header

Remediation: Identify the web server / reverse proxy in front of the application.; Add the missing security header globally so every response carries it.; Verify with a re-scan that the header is present on all endpoints.

6. [MEDIUM] Missing security header: X-Content-Type-Options

Target: <http://scanme.nmap.org>

Evidence: GET <http://scanme.nmap.org> -> no 'X-Content-Type-Options' header

Remediation: Identify the web server / reverse proxy in front of the application.; Add the missing security header globally so every response carries it.; Verify with a re-scan that the header is present on all endpoints.

7. [MEDIUM] Missing security header: Referrer-Policy

Target: <http://scanme.nmap.org>

Evidence: GET <http://scanme.nmap.org> -> no 'Referrer-Policy' header

Remediation: Identify the web server / reverse proxy in front of the application.; Add the missing security header globally so every response carries it.; Verify with a re-scan that the header is present on all endpoints.

8. [MEDIUM] Missing security header: Permissions-Policy

Target: <http://scanme.nmap.org>

Evidence: GET <http://scanme.nmap.org> -> no 'Permissions-Policy' header

Remediation: Identify the web server / reverse proxy in front of the application.; Add the missing security header globally so every response carries it.; Verify with a re-scan that the header is present on all endpoints.